

The background of the slide features a complex network diagram with numerous nodes and connecting lines, rendered in a light blue color against a dark blue background. The nodes are small squares, and the lines are thin, creating a web-like structure that fills the entire slide.

Aislamiento de Contenedores en **Seguridad Cloud**

Sesión 3

Objetivos de la Sesión

1. Entender la importancia del aislamiento de contenedores en la seguridad cloud.
2. Aprender a firmar y verificar imágenes para garantizar la integridad.
3. Dominar prácticas de construcción de imágenes seguras.
4. Implementar políticas de seguridad en tuberías CI/CD.

Introducción al Aislamiento de Contenedores

- **Concepto clave:**

- Los contenedores son la base de aplicaciones cloud, pero una imagen comprometida pone en riesgo toda la infraestructura.

- **Cita relevante:**

"La integridad de las imágenes es indispensable para evitar malware y vulnerabilidades." (Smith y Johnson, 2022)

Firma y Verificación de Imágenes

- **Herramientas clave:** Docker Content Trust (DCT) y Notary.
- **Proceso:**
 - **Firma:** El desarrollador firma la imagen con una clave privada.
 - **Verificación:** El sistema valida la firma antes del despliegue.
- **Ejemplos prácticos (comandos):**

```
1 # Habilitar Docker Content Trust
2 export DOCKER_CONTENT_TRUST=1
3 # Descargar imagen firmada
4 docker pull myregistry/myimage:latest
```

- **Visual:** Flujo de firma/verificación con DCT
-

Construcción de Imágenes Seguras

- **Prácticas clave:**
 - Minimizar capas:** Solo incluye dependencias esenciales.
 - Eliminar paquetes innecesarios:** Ejemplo: servidor web en una imagen de backend.
 - Usar imágenes base reducidas:**

Ejemplo de Dockerfile seguro: archivo Docker

```
1 FROM alpine:latest
2 RUN apk add --no-cache python3 && \
3     rm -rf /var/cache/apk/*
```


Políticas de Seguridad en CI/CD

Integración de escaneo de vulnerabilidades:

- **Herramientas:** Trivy, Anchore, Clair.
- **Ejemplo en GitHub Actions (Trivy):**

```
1 v - name: Escanear con Trivy
2 v   run: |
3       trivy image --exit-code 1 --format table myregistry/myimage:latest
```

Automatización de pruebas de seguridad:

- **SAST:** Análisis estático (SonarQube).
- **DAST:** Pruebas dinámicas (OWASP ZAP)

Demostración Práctica

•Actividad guiada:

- Configurar Docker Content Trust en un entorno local.
- Ejecutar un escaneo de vulnerabilidades con Trivy en una imagen.
- Integrar OWASP ZAP en un pipeline Jenkins.

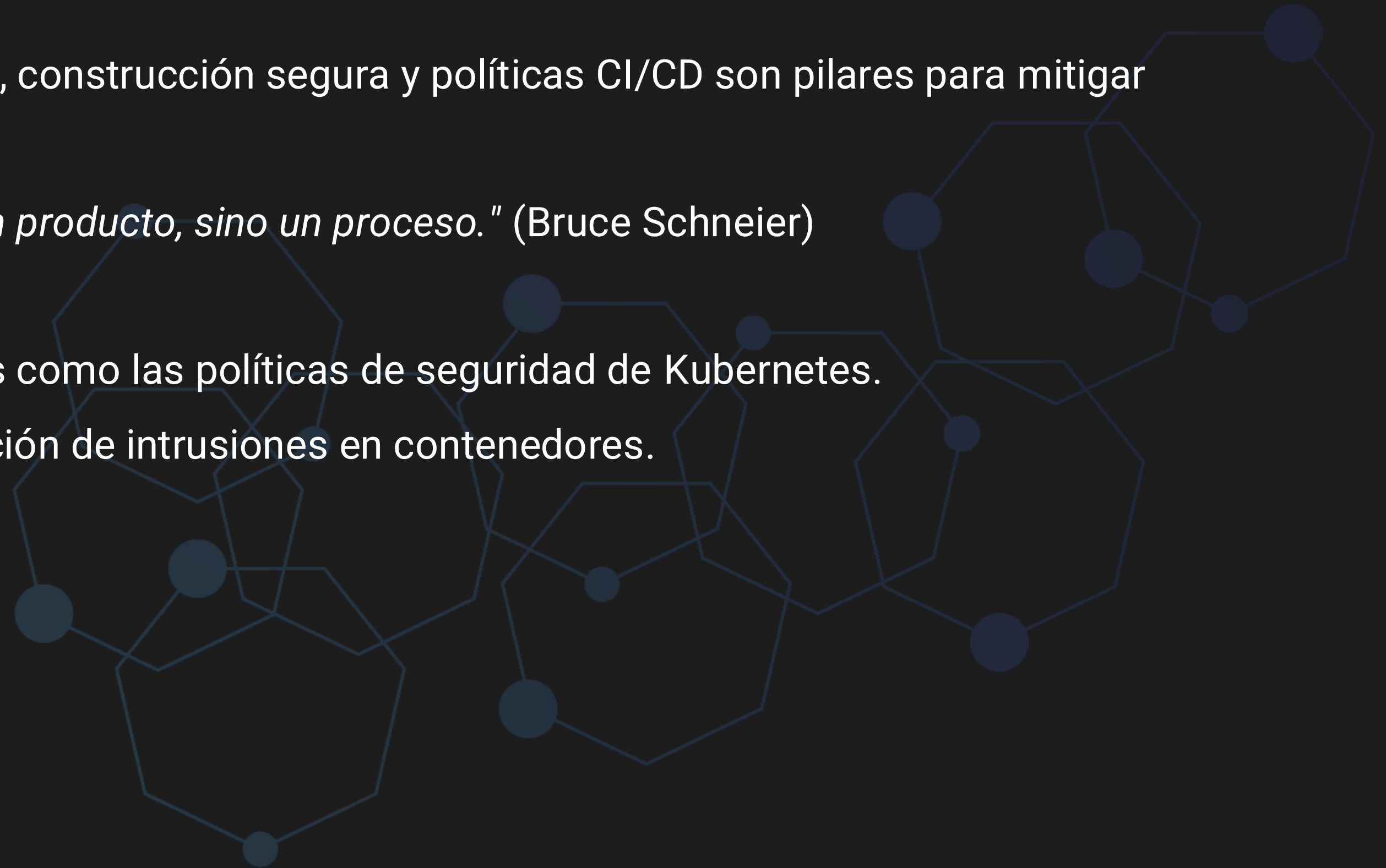
Conclusión

•Resumen:

- La firma de imágenes, construcción segura y políticas CI/CD son pilares para mitigar riesgos.
- *"La seguridad no es un producto, sino un proceso."* (Bruce Schneier)

•Próximos pasos:

- Explorar herramientas como las políticas de seguridad de Kubernetes.
- Profundizar en detección de intrusiones en contenedores.



Preguntas

- **Indicaciones para el instructor:** Fomentar preguntas sobre casos reales (ej: "¿Qué pasa si una imagen firmada se ve comprometida?").
- Discutir desafíos en la implementación de políticas CI/CD en equipos grandes.



Referencias

- Smith y Johnson (2022), *Cloud Security Journal* .
- Documentación de Docker y Trivy.
- Guía del usuario de OWASP ZAP.

Continúe con las
actividades
